TLS13

TLS1.2 구조와 TLS1.3 개선

연관 기출 · 136-2-6

한눈에 이해

서로의 신원과 공유키를 합의한 뒤 데이터를 인증 암호로 보호하며, 예전 기능을 제거해 공격 여지를 줄입니다.

정의와 핵심 원리

TLS는 전송 중인 데이터의 기밀성과 무결성을 보장하고 통신 상대를 인증하는 프로토콜입니다. 핸드셰이크에서 버전과 알고리즘을 협상하고 키를 설정하며, 인증서 기반 연결에서는 서버 신원을 확인합니다. 레코드 계층은 설정된 키로 응용 데이터를 보호합니다.

• TLS 1.3의 기본 흐름은 ClientHello(key_share 등) → ServerHello → 암호화된 확장·인증서·CertificateVerify·Finished → 클라이언트 Finished입니다. 이전 판보다 왕복을 줄일 수 있으며, 사전 공유 키(PSK)로 세션을 재개하거나 클라이언트 인증을 요청할 수 있습니다. 서버 인증에서는 인증서 체인, 호스트명과 유효 상태를 검증합니다.

• TLS 1.3은 이전 키 교환 방식과 CBC 등 구형 선택지를 줄이고, AEAD와 HKDF 기반의 키 스케줄을 사용합니다. 인증서 서명 알고리즘, 키 교환과 레코드 암호는 서로 다른 역할입니다. TLS 1.2의 보안 수준은 실제 설정과 사용하는 알고리즘으로 판단합니다.

• 0-RTT 조기 데이터는 왕복을 기다리지 않아 지연을 줄일 수 있지만, 공격자가 같은 요청을 다시 보낼 위험이 있습니다. 송금처럼 한 번만 처리해야 하는 행위에는 별도의 방어가 필요합니다. 핸드셰이크 이후에도 응용 권한, 쿠키·로그, 키 보관과 종단의 취약점을 관리합니다. 전방향 안전성은 키 교환과 운영 조건을 확인합니다.

• TLS 1.2는 Record 계층 위에 Handshake·ChangeCipherSpec·Alert와 응용 데이터를 다룹니다. 인증서 기반 ECDHE·클라이언트 인증 없음·최초 full handshake의 예는 ClientHello → ServerHello·Certificate·ServerKeyExchange·ServerHelloDone → ClientKeyExchange·ChangeCipherSpec·Finished → 서버 ChangeCipherSpec·Finished입니다. ChangeCipherSpec은 Handshake 메시지와 별도 콘텐츠 유형이며 키교환·상호인증·세션 재개 조건에 따라 흐름이 달라집니다.

• 정적 RSA 키교환은 전방향 안전성을 제공하지 않으며 TLS 1.3은 정적 RSA/DH를 제거했습니다. CBC 등 구형 레코드 암호를 제거하고 AEAD만 허용하며, ServerHello 뒤의 핸드셰이크 메시지를 암호화합니다.

구조·비교·판단

구분	핵심 원리	적용·한계
TLS 1.2	여러 구형 알고리즘을 지원	안전한 설정과 패치 필요
TLS 1.3	AEAD만 허용하고 왕복을 줄임	호환성과 트래픽 검사 방식 확인
0-RTT	응용 데이터를 일찍 전송	재전송 위험과 업무 멱등성 확인

적용 예제

조기 데이터와 중복 송금

강사 생성 학습 예제입니다. 공식 기준답안이 아닙니다.

조건: 재개한 TLS 세션에서 송금 POST 요청을 0-RTT로 받는다고 가정합니다.

1. 네트워크 공격자가 같은 조기 데이터를 다시 보내는 경우를 위협 모형에 포함합니다.

2. 조기 데이터로 송금을 받지 않는 방법을 먼저 검토합니다. 허용한다면 요청 식별자와 중복 검사를 적용합니다.

3. 인증이 끝났는지와 업무 권한을 확인하고 원장에는 같은 송금을 한 번만 반영합니다.

4. 읽기 요청도 부수 효과, 데이터 민감도, 같은 요청을 다시 보내도 안전한지 확인합니다.

결과·해석: 지연을 줄이는 이점과 업무 데이터가 중복 처리될 위험을 따로 판단합니다.

전제·주의: 제품별 TLS 설정과 지원 알고리즘은 해당 버전의 공식 문서에서 확인합니다.

답안 골격과 혼동 방지

구조 → 핸드셰이크 순서 → TLS 1.2와 1.3 비교 → 0-RTT → 인증서 검증과 운영

- TLS 1.2는 사용 중인 알고리즘과 실제 설정을 보고 취약 여부를 판단합니다.
- 전송을 암호화하더라도 응용에서 사용자의 권한을 확인합니다.

내용을 가리고 회상

1. TLS 1.3에서 사라진 구형 기능은 무엇이며 그 영향은 무엇입니까?

2. CertificateVerify와 Finished는 각각 무엇을 확인합니까?

3. 송금을 0-RTT로 받으면 어떤 위험을 막아야 합니까?

적용 기준과 근거

명시한 출처 판본의 원리를 설명하며 제품별 구현 차이는 별도 확인합니다.

내용 검토 상태: 출처 확인. 출처 확인은 공식 정답이나 학습 성취를 뜻하지 않습니다.

출처별 상세 열람 범위는 위키의 출처 기록에서 확인합니다.

- RFC8446: TLS1.3 - Eric Rescorla / IETF; 2018-08; 확인 2026-11-05.
- The Transport Layer Security Protocol Version 1.2 - T. Dierks, E. Rescorla / IETF; 2008-08; 확인 2026-11-05.